Software Engineering

UE24CS341A

Rehaan Jose Mathew
PES2UG24CS400
G Section

Problem

Lab 5: Static Code Analysis - Event Management System (event_manager.py)

Repository Link

https://github.com/SETAPESU26/L5_31_event_manager

Program Output (Before Fixes)

```
PS C:\Users\rehaa\Documents\swe-lab\Lab_5\L5_31_event_manager> python event_manager.py
Alumni Dinner is full, cannot add Meena
No such event: Workshop
Seats left at Tech Meetup: 1
Seats left at Alumni Dinner: 0
Tech Meetup guests: Asha, Ravi
Tech Meetup is Upcoming
Alumni Dinner is Completed
Lucky draw winner: Asha
Events restored from file: 2
Venues: ['Hall A', 'Rooftop']
PS C:\Users\rehaa\Documents\swe-lab\Lab_5\L5_31_event_manager>
```

Pylint Report (Before)

```
PS C:\Users\rehaa\Documents\swe-lab\Lab_5\L5_31_event_manager> python -m pylint event_manager.py
************* Module event_manager
event_manager.py:1:0: C0114: Missing module docstring (missing-module-docstring)
event_manager.py:9:0: C0116: Missing function or method docstring (missing-function-docstring)
event_manager.py:9:0: C0103: Function name "createEvent" doesn't conform to snake_case naming style (invalid-name)
event_manager.py:9:16: C0103: Argument name "eventName" doesn't conform to snake_case naming style (invalid-name)
event_manager.py:9:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
event_manager.py:15:0: C0116: Missing function or method docstring (missing-function-docstring)
event_manager.py:15:0: C0103: Function name "registerGuest" doesn't conform to snake_case naming style (invalid-name)
event_manager.py:15:18: C0103: Argument name "eventName" doesn't conform to snake_case naming style (invalid-name)
event_manager.py:27:0: C0116: Missing function or method docstring (missing-function-docstring)
event_manager.py:27:0: C0103: Function name "seatsLeft" doesn't conform to snake_case naming style (invalid-name)
event_manager.py:27:14: C0103: Argument name "eventName" doesn't conform to snake_case naming style (invalid-name)
event_manager.py:32:0: C0116: Missing function or method docstring (missing-function-docstring)
event_manager.py:32:0: C0103: Function name "eventStatus" doesn't conform to snake_case naming style (invalid-name)
event_manager.py:32:16: C0103: Argument name "eventDate" doesn't conform to snake_case naming style (invalid-name)
event_manager.py:33:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (no-else-return)
event_manager.py:39:0: C0116: Missing function or method docstring (missing-function-docstring)
event_manager.py:39:0: C0103: Function name "guestReport" doesn't conform to snake_case naming style (invalid-name)
event_manager.py:39:16: C0103: Argument name "eventName" doesn't conform to snake_case naming style (invalid-name)
event_manager.py:39:27: C0103: Argument name "sortOrder" doesn't conform to snake_case naming style (invalid-name)
event_manager.py:39:27: W0613: Unused argument 'sortOrder' (unused-argument)
event_manager.py:44:0: C0116: Missing function or method docstring (missing-function-docstring)
event_manager.py:44:0: C0103: Function name "saveEvents" doesn't conform to snake_case naming style (invalid-name)
event_manager.py:44:15: C0103: Argument name "fileName" doesn't conform to snake_case naming style (invalid-name)
event_manager.py:49:0: C0116: Missing function or method docstring (missing-function-docstring)
event_manager.py:49:0: C0103: Function name "loadEvents" doesn't conform to snake_case naming style (invalid-name)
event_manager.py:49:15: C0103: Argument name "fileName" doesn't conform to snake_case naming style (invalid-name)
event_manager.py:54:0: C0116: Missing function or method docstring (missing-function-docstring)
event_manager.py:54:0: C0103: Function name "printBadges" doesn't conform to snake_case naming style (invalid-name)
event_manager.py:54:16: C0103: Argument name "eventName" doesn't conform to snake_case naming style (invalid-name)
event_manager.py:59:0: C0116: Missing function or method docstring (missing-function-docstring)

-----------------------------------
Your code has been rated at 4.64/10

PS C:\Users\rehaa\Documents\swe-lab\Lab_5\L5_31_event_manager>
```

Flake8 Report (Before)

```
PS C:\Users\rehaa\Documents\swe-lab\Lab_5\L5_31_event_manager> python -m flake8 event_manager.py
event_manager.py:61:43: E231 missing whitespace after ','
event_manager.py:66:9: E225 missing whitespace around operator
event_manager.py:75:28: E261 at least two spaces before inline comment
event_manager.py:79:1: E305 expected 2 blank lines after class or function definition, found 1
PS C:\Users\rehaa\Documents\swe-lab\Lab_5\L5_31_event_manager>
```

Bandit Report (Before)

```
PS C:\Users\rehaa\Documents\swe-lab\Lab_5\L5_31_event_manager> python -m bandit -r event_manager.py
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.14.7
Run started:2026-10-16 04:19:14.627010+00:00

Test results:
>> Issue: [B403:blacklist] Consider possible security implications associated with pickle module.
   Severity: Low   Confidence: High
   CWE: CWE-502 (https://cwe.mitre.org/data/definitions/502.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b403-import-pickle
   Location: .\event_manager.py:2:0
1       import os
2       import pickle
3       import random

--------------------------------------------------
>> Issue: [B301:blacklist] Pickle and modules that wrap it can be unsafe when used to deserialize untrusted data, possible security issue.
   Severity: Medium   Confidence: High
   CWE: CWE-502 (https://cwe.mitre.org/data/definitions/502.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b301-pickle
   Location: .\event_manager.py:51:15
50          with open(fileName, "rb") as f:
51              return pickle.load(f)
52

--------------------------------------------------
>> Issue: [B605:start_process_with_a_shell] Starting a process with a shell, possible injection detected, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605_start_process_with_a_shell.html
   Location: .\event_manager.py:56:4
55          # Helper kept for the lab: not called by the demo
56          os.system("lp badges_" + eventName + ".txt")
57

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\event_manager.py:72:13
71          print("Alumni Dinner is", eventStatus(date(2020, 5, 1)))
72          winner = random.choice(events["Tech Meetup"]["guests"])
73          print("Lucky draw winner:", winner)

--------------------------------------------------

Code scanned:
        Total lines of code: 58
        Total lines skipped (#nosec): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 2
                Medium: 1
                High: 1
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 4
Files skipped (0):
```

Issues Identified

Issue	Type	Line(s)	Description	Fix Approach
Shell command injection via os.system (B605, High)	Security	48	printBadges builds a shell command by concatenating the event name, so a name like x; rm -rf ~ runs arbitrary commands.	Validate the name, then call subprocess.run(["/usr/bin/lp", file], check=True) with an argument list and no shell.
Mutable default argument guests=[] (W0102)	Bug	8-10	The default list is created once and shared by every event created without guests. Registering Meena for "Alumni Dinner" was rejected as "full", and Tech Meetup's guests leaked into it. Output showed Alumni Dinner with 0 seats left instead of 1.	Default to None, then store list(guests) if guests else [] so each event owns its list.
Unsafe deserialization with pickle.load (B301, Medium; B403, Low)	Security	2, 44	Loading a pickle file can execute arbitrary code if the file is tampered with.	Replace pickle with json (json.dump / json.load) and save to events.json.
Weak PRNG for lucky draw (B311, Low)	Security	63	random.choice is predictable, which is unsuitable for a draw. It also raises IndexError if the guest list is empty.	New draw_winner() using secrets.choice, returning None when there are no guests.
Unused argument sortOrder (W0613)	Code quality	34	guestReport accepts sortOrder but ignores it, so callers think they control ordering.	Replace it with a working reverse=False option passed to sorted().
main() runs on import	Code quality	70	The demo runs as soon as the module is imported, which also makes it untestable.	Wrap the call in if __name__ == "__main__":.
Non-snake_case names (C0103)	Style	8-50	createEvent, eventName, seatsLeft, etc. break PEP 8 naming.	Rename to create_event, event_name, seats_left, etc.
Missing docstrings (C0114, C0116)	Style	1, all functions	No module or function documentation.	Add a module docstring and a one-line docstring per function.
Unnecessary else after return (R1705)	Style	29-32	The else branch in eventStatus is redundant.	Remove the else and de-indent the final return.
Missing encoding on open()	Style / portability	39, 43	Platform-default encoding is used.	Pass encoding="utf-8" in text mode.
Blank lines and spacing (E302, E305, E128, E231, E225, E261)	Style	8-70	Missing blank lines between functions, bad continuation indent, missing spaces after , and around =, inline comment spacing.	Reformat to PEP 8 (two blank lines, correct spacing).

Fixed Code

```
PS C:\Users\rehaa\Documents\swe-lab\Lab_5\L5_31_event_manager> cat .\event_manager.py
import os
import pickle
import random
from datetime import date

events = {}


def createEvent(eventName, venue, capacity=50, guests=[]):
    events[eventName] = {"venue": venue, "capacity": capacity,
                         "guests": guests}
    return events[eventName]


def registerGuest(eventName, guest):
    event = events.get(eventName)
    if event is None:
        print("No such event:", eventName)
        return False
    if len(event["guests"]) >= event["capacity"]:
        print(eventName, "is full, cannot add", guest)
        return False
    event["guests"].append(guest)
    return True


def seatsLeft(eventName):
    event = events[eventName]
    return event["capacity"] - len(event["guests"])


def eventStatus(eventDate):
    if eventDate >= date.today():
        return "Upcoming"
    else:
        return "Completed"


def guestReport(eventName, sortOrder):
    names = sorted(events[eventName]["guests"])
    return ", ".join(names)


def saveEvents(fileName="events.pkl"):
    with open(fileName, "wb") as f:
        pickle.dump(events, f)
```

```
def loadEvents(fileName="events.pkl"):
    with open(fileName, "rb") as f:
        return pickle.load(f)


def printBadges(eventName):
    # Helper kept for the lab: not called by the demo
    os.system("lp badges_" + eventName + ".txt")


def main():
    createEvent("Tech Meetup", "Hall A", 3)
    createEvent("Alumni Dinner", "Rooftop",2)
    registerGuest("Tech Meetup", "Asha")
    registerGuest("Tech Meetup", "Ravi")
    registerGuest("Alumni Dinner", "Meena")
    registerGuest("Workshop", "Kiran")
    left=seatsLeft("Tech Meetup")
    print("Seats left at Tech Meetup:", left)
    print("Seats left at Alumni Dinner:", seatsLeft("Alumni Dinner"))
    print("Tech Meetup guests:", guestReport("Tech Meetup", "name"))
    print("Tech Meetup is", eventStatus(date(2099, 1, 15)))
    print("Alumni Dinner is", eventStatus(date(2020, 5, 1)))
    winner = random.choice(events["Tech Meetup"]["guests"])
    print("Lucky draw winner:", winner)
    saveEvents()
    restored = loadEvents() # reload to confirm the save worked
    print("Events restored from file:", len(restored))
    print("Venues:", [e["venue"] for e in restored.values()])

main()
PS C:\Users\rehaa\Documents\swe-lab\Lab_5\L5_31_event_manager>
```

Program Output (After Fixes)

```
PS C:\Users\rehaa\Documents\swe-lab\Lab_5\L5_31_event_manager> python .\event_manager.py
No such event: Workshop
Seats left at Tech Meetup: 1
Seats left at Alumni Dinner: 1
Tech Meetup guests: Asha, Ravi
Tech Meetup is Upcoming
Alumni Dinner is Completed
Lucky draw winner: Asha
Events restored from file: 2
Venues: ['Hall A', 'Rooftop']
PS C:\Users\rehaa\Documents\swe-lab\Lab_5\L5_31_event_manager>
```

Pylint Report (After)

```
PS C:\Users\rehaa\Documents\swe-lab\Lab_5\L5_31_event_manager> python -m pylint event_manager.py
************* Module event_manager
event_manager.py:112:0: C0304: Final newline missing (missing-final-newline)

-------------------------------------------------------------------
Your code has been rated at 9.84/10 (previous run: 4.64/10, +5.20)

PS C:\Users\rehaa\Documents\swe-lab\Lab_5\L5_31_event_manager>
```

Flake8 Report (After)

```
PS C:\Users\rehaa\Documents\swe-lab\Lab_5\L5_31_event_manager> python -m flake8 event_manager.py
event_manager.py:112:11: W292 no newline at end of file
```

Bandit Report (After)

```
PS C:\Users\rehaa\Documents\swe-lab\Lab_5\L5_31_event_manager> python -m bandit -r event_manager.py
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.14.7
[manager]       WARNING Test in comment: used is not a test name or id, ignoring
[manager]       WARNING Test in comment: only is not a test name or id, ignoring
[manager]       WARNING Test in comment: with is not a test name or id, ignoring
[manager]       WARNING Test in comment: a is not a test name or id, ignoring
[manager]       WARNING Test in comment: fixed is not a test name or id, ignoring
[manager]       WARNING Test in comment: argument is not a test name or id, ignoring
[manager]       WARNING Test in comment: list is not a test name or id, ignoring
[manager]       WARNING Test in comment: no is not a test name or id, ignoring
[manager]       WARNING Test in comment: shell is not a test name or id, ignoring
[manager]       WARNING Test in comment: input is not a test name or id, ignoring
[manager]       WARNING Test in comment: validated is not a test name or id, ignoring
[manager]       WARNING Test in comment: above is not a test name or id, ignoring
Run started:2026-10-16 04:30:49.230601+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 86
        Total lines skipped (#nosec): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
```

Reflections

1. Which tool was most useful, and why?

Ans: Bandit was the most useful for impact: it flagged the one High-severity issue (`os.system` with a concatenated string) that could let an attacker run arbitrary commands. Pylint gave the most findings and its `dangerous-default-value` warning pointed straight at the real logic bug. Flake8 was purely about formatting. No tool flagged the symptom that revealed the bug (Alumni Dinner showing "full" with 0 seats), so reading the program output was just as important.

2. Were there false positives or issues you chose not to fix?

Ans: Bandit's remaining low-severity subprocess notes (B404, B603) are expected for any code that runs a subprocess. They are not real vulnerabilities here because no shell is used, the argument is a list, the executable is a fixed path and the event name is validated. I suppressed them with an explanatory `# nosec` comment rather than removing the badge feature.

3. How did you fix the shared-guest-list bug?

Ans: `guests=[]` is evaluated once at function definition, so every event created without an explicit list shared the same list object. Registering guests for one event filled the other. I changed the default to `None` and create a fresh list per event. After the fix, Tech Meetup has 1 seat left and Alumni Dinner has 1 seat left, and Meena registers successfully.

4. How would you integrate static analysis into a real workflow?

Ans: Run Pylint, Flake8 and Bandit in a pre-commit hook for fast local feedback and in CI (e.g. GitHub Actions) on every pull request, failing the build on Bandit medium/high findings and on a Pylint score below a threshold (e.g. 9.5). Keep a config file (`.pylintrc`, `setup.cfg`, `.bandit`) so suppressions are explicit and reviewed. Static tools complement, not replace, tests and code review, since logic bugs like the shared list need running the program or writing tests to find.